

自動生成した訓練用標的型メール配信システムの実用性検証

Practicality verification of automatic delivery system for automatically generated training targeted emails

指導教員 五味 悠一郎 准教授

1076 徳野 響

1. まえがき

サイバー攻撃の1つとして、標的型攻撃がある。標的型攻撃による機密情報の窃取は、IPAの情報セキュリティ10大脅威に2016年から9年間連続で選出されており、優先的に対策を行うべき攻撃の1つである¹⁾。標的型攻撃において、標的組織のネットワークへの初期侵入時にメールを用いて行われる攻撃手法を標的型メール攻撃という。標的型メール攻撃による被害は、システムによるセキュリティのみでは完全に回避することが難しく、技術的セキュリティだけでなく人的セキュリティも併せて行うことが重要である。

2. 目的・目標

標的型メール攻撃への対策の1つとして、標的型メール訓練が挙げられる。しかし、標的型メール訓練を行うサービス費用の問題から、企業が標的型メール訓練を積極に行えない状況にある。また、サービスを利用する以外の方法として、独自に標的型メール訓練環境を用意することが考えられるが、技術的な知識やノウハウが求められるため困難である場合が多い。そこで、「自動生成した訓練用標的型メールを用いた標的型メール訓練システム」を開発し、企業が積極的に標的型メール訓練を行える状況を作る。

2021年に釜田は、N階マルコフ連鎖を用いた訓練用標的型メール自動生成システムを開発した。自動生成した訓練用標的型メールは、不自然な文章や文脈を含んでいた²⁾。訓練者のレベルが高い場合の訓練用標的型メールとしては不十分であるため、不自然な文章や文脈を含まない訓練用標的型メールの自動生成システムを開発する必要がある。また、釜田はメール配信システムも開発した。しかし、メール配信システムにおけるメール送信機能のみの開発であり、訓練用標的型メール自動生成システムと連携する機能がない。他にも、40以上の送信先を考慮した機能テストを行っていないという問題がある。

本研究では、「自動生成した訓練用標的型メールを用いた標的型メール訓練」を行える状況を作るために、「Geminiを用いた訓練用標的型メール自動生成システム」と「自動生成した訓練用標的型メールを配信するシステム」、および「URLクリック者検知システム」を開発し評価した。

3. 原理

3.1 URLパラメータ(クエリストリングパラメータ)

URLパラメータとは、Webプログラム呼び出しのURLの中に含まれるパラメータのことである³⁾。URLの後ろに"?"(クエスチョンマーク)を挟んで、パラメータ名とパラメータの値が"=" (イコール)で結ばれる形で記述される。Webアプリケーションに対してURLパラメータで値を渡すことで、値に応じた処理を行うことができる。

4. システム概要

4.1 Geminiを用いた訓練用標的型メール自動生成システム

Gemini APIとGoogle Colaboratoryを使用して、訓練用標的型メール自動生成プログラムを開発した。プログラムを実行することで、プログラム実行者の入力に対応した1通のメール文章が自動生成される。

4.2 メール配信システム

訓練用標的型メール自動生成システムで生成したメール文章を取得し、メールとして送信するスクリプトを開発した。このスクリプトはGoogle Drive上のCSVファイルに、訓練者の氏名やメールアドレスを入力して実行することで、自動生成したメール文章内の伏字を入力内容に置き換え、対応したメー

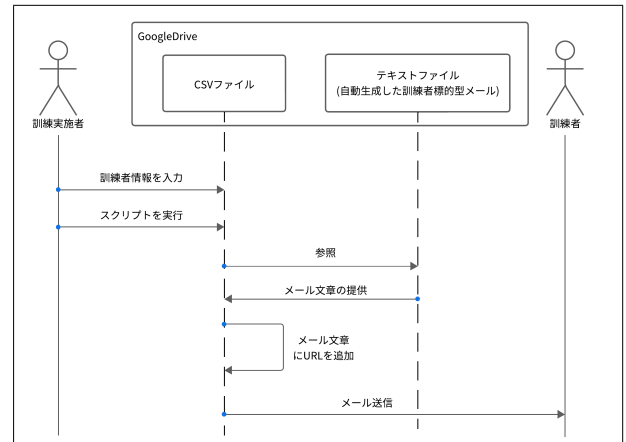


図1 メール送信機能シーケンス図

ルアドレスに自動生成したメール文章を送信する。指定したURLを、指定した文章にリンクとして埋め込む機能も有する。中小企業における訓練を想定しているため、中小企業基本法の定義に基づき、常時雇用する従業員の数として最も多い人数である300人を基準として、訓練対象者数の最大を300人とした⁴⁾。中小企業における訓練を想定しているが、大企業等においても部や課を対象とすれば利用可能である。このスクリプトでは、訓練者ごとにユニークな数値を設定し、メール送信時にURLパラメータとして組み込んでいる。このURLパラメータは、後述するURLクリック者検知機能に利用している。メール送信機能のシーケンス図を図1に示す。

4.3 URLクリック者検知システム

Google Cloudを利用して、URLクリック者検知を行うWebプログラムを作成した。このWebプログラムはアクセス者のURLパラメータを取得し、CSVファイルに保存する。URLパラメータにidとnumの2つの値を設定することで、URLクリック者を判断可能にしている。検知したURLクリック者には通知を行わないシステムとした。通知を行わないことで、システム管理者による柔軟な利用を可能にするとともに、ユーザ間で訓練メールであることが共有されないようにした。

5. 評価方法

5.1 自動生成した訓練用標的型メールの精度評価

文章精度の高さを盲検法により評価した。盲検法では、「人が作成したメール文章」と「N階マルコフ連鎖を用いたシステムによるメール文章」、および「Gemini APIを用いたシステムによるメール文章」が「通常のメール」か「標的型メール」かを選択していただいた。評価の結果、「標的型メール」であると判断された割合が「N階マルコフ連鎖を用いたシステムによるメール文章」よりも低く、「人が作成したメール文章」よりも同等あるいはそれ以上の評価の場合、不自然な文章を含まない訓練用標的型メールを自動生成できるといえる。

各手法による訓練用標的型メールの比較を行うため、盲検法の問題は「人が作成したメール文章」を11問、「N階マルコフ連鎖を用いたシステムによるメール文章」を11問、「Gemini APIを用いたシステムによるメール文章」を11問の計33問を使用した。実験は、GoogleFormで作成したテストを用いて行った。被験者は日常的にメールを利用している大学生11人である。

5.2 メール配信機能と検知機能の評価

開発したメール配信システムを使用し、機能テストを行った。この機能テストでは、5つのメールアドレスに対して、URL クリック者検知機能をもつ Web サイト URL を含んだ自動生成した訓練用標的型メールを、各 60 通ずつの計 300 通送信した。送信したメール文章では、「ダウンロードはこちらから」という文章に「URL クリック者検知機能をもつ Web サイト URL」の埋め込みを行いリンクにした。伏字となっている氏名を受信者ごとに置換した 300 通のメールがすべて正常に送受信されたこと、およびメール文章に含まれる Web サイト URL をクリックした場合に、メール受信者を識別する URL パラメータが CSV ファイルに記録されることを確認した。

メール配信システムにおける訓練対象者数の上限は 300 名であるため、機能テストでの送信メール数を 300 通とした。各メールアドレスに氏名と対応した訓練用標的型メールが送信されたことを確認するため、送信先のメールアドレス数は、実際に使用している 5 つとした。メールアドレスは 300 個用意することが理想であるが、利用可能なメールアドレスが 5 つであったため、各氏名に 5 つのメールアドレスをランダムに割り当てて、各メールアドレスにメールを送信する方法で機能テストを行った。

6. 結果

6.1 盲検法による評価結果

実験の結果、「Gemini API を用いたシステムによるメール文章」が「標的型メール」と判断された割合は平均で 43 %であった。対して「人が作成したメール文章」は 36.4 %、「N 階マルコフ連鎖を用いたシステムによるメール文章」は 75.2 %であった。各手法ごとに「標的型メール」と判断された割合をまとめたグラフを図 2 に示す。

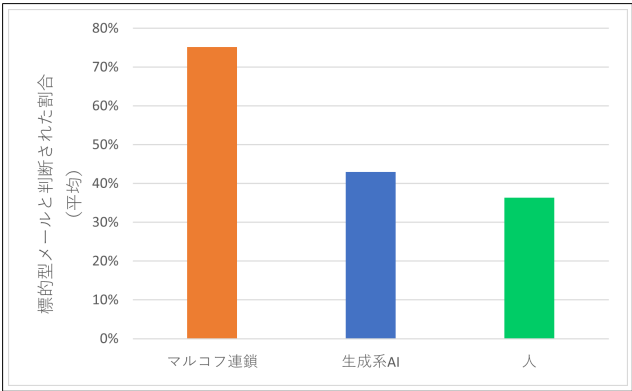


図 2 標的型メールと判断された割合

6.2 システムの機能テスト結果

メール配信システムにより、300 通のメールを正常にすべて送受信できた。また、各メール文章に含まれる URL パラメータを、CSV ファイルにすべて記録できていることが確認できた。各メールアドレスにて、正常に受信したメール文章の例を図 3 に示す。なお、図 3 は PC の Web アプリケーション Gmail で確認したメール文章である。

7. 考察

「Gemini API を用いたシステムによるメール文章」は、「標的型メール」とであると判断された割合が「N 階マルコフ連鎖を用いたシステムによるメール文章」よりも低く、「人が作成したメール文章」よりも高い。そのため、「Gemini API を用いたシステムによるメール文章」は、訓練者が違和感を感じるが不自然すぎないメール文章であり、訓練者のレベルが高い場合の訓練用標的型メールとして利用可能であるといえる。

メール配信システムにより、300 通のメールを正常にすべて

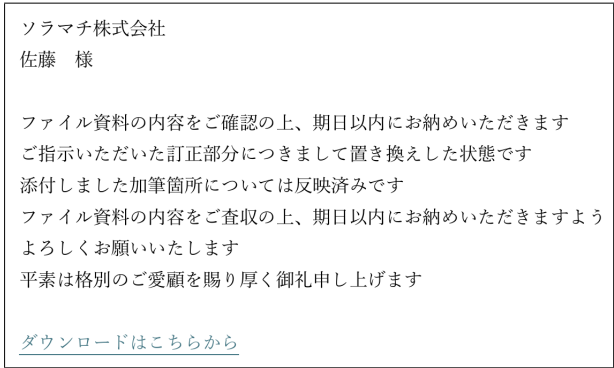


図 3 送信したメール文章 (氏名: 佐藤, Gmail)

送受信できた。また、各メール文章に含まれる URL パラメータを、すべて記録できていることが確認できた。この結果から、「自動生成した訓練用標的型メールを用いた訓練用標的型メール配信システム」は、実用に耐えるといえる。なお、機能テストでは 5 個のメールアドレスにメールを送信したが、300 個のメールアドレスに 1 通ずつメールを送信する場合は、途中のメールサーバでブロックされるなど、同一環境であっても同様の結果を得られない可能性がある。

8. むすび

本研究では、「Gemini を用いた訓練用標的型メール自動生成システム」と「自動生成した訓練用標的型メールを配信するシステム」、および「URL クリック者検知システム」を開発し評価を行った。「Gemini API を用いたシステムによるメール文章」は、訓練者にとって違和感を感じるが不自然すぎないメール文章であり、訓練者のレベルが高い場合の訓練用標的型メールとして利用可能であるといえる。「自動生成した訓練用標的型メールを配信するシステム」、および「URL クリック者検知システム」は自動生成した訓練用標的型メールを送信、およびクリック者を検知できおり、URL が含まれる自作標的型メールを用いた標的型メール訓練システムとして利用可能であるといえる。しかし、添付ファイルを用いた標的型メールに対する訓練ができないため、「添付ファイルの送信、およびファイルダウンロードの検知機能を実装すること」により、こうした訓練を可能にする必要がある。

参考文献

- 1) 独立行政法人情報処理推進機構 (IPA): 情報セキュリティ 10 大脅威 2024. <https://www.ipa.go.jp/security/10threats/10threats2024.html>, 参照 2024-08-03.
- 2) 金田諒大: 標的型メールを元に自動生成した訓練用標的型メールの配信システム開発, 2021, 日本大学理工学部卒業論文.
- 3) 独立行政法人情報処理推進機構 (IPA): 第 5 章 3. コンテンツ間パラメータ対策. <https://www.ipa.go.jp/archive/security/vuln/programming/web/chapter5/5-3.html>, 参照 2024-08-03.
- 4) 中小企業庁: 中小企業法. https://www.chusho.meti.go.jp/faq/faq/faq01_teigi.html, 参照 2024-08-03.